**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG**
**KHOA AN TOÀN THÔNG TIN**

# BÁO CÁO BÀI TẬP LỚN
# HỌC PHẦN: AN TOÀN MẠNG
# MÃ HỌC PHẦN: INT1482

## ĐỀ TÀI: AN TOÀN DỊCH VỤ TRUYỀN NHẬN TỆP (FTP VS FTPS/SFTP)

Sinh viên thực hiện:

| | |
|---|---|
| B23DCAT080 | Ngô Quý Trường Giang |
| B23DCAT150 | Trần Quốc Khánh |
| B23DCAT115 | Trần Huy Hoàng |
| B23DCAT015 | Nguyễn Thị Ngọc Anh |
| B23DCAT036 | Đặng Trần Hải Đăng |

Tên nhóm: 05

Tên lớp: INT1482-20261-02

Giảng viên hướng dẫn: TS. Nguyễn Ngọc Điệp

**HÀ NỘI 2026**

## PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

| TT | Công việc / Nhiệm vụ | SV thực hiện | Thời hạn hoàn thành |
|---|---|---|---|
| 1 | - Điều phối, theo dõi tiến độ hoàn thành Demo.<br>- Thiết kế cấu hình phân vùng mạng và quy hoạch IP.<br>- Chịu trách nhiệm cài đặt cấu hình mạng lõi.<br>- Tổng hợp báo cáo chung. | Ngô Quý Trường Giang | 13/10/2026 |
| 2 | - Khảo sát lý thuyết về quản lý bản vá và quy trình 6 bước khắc phục lỗ hổng.<br>- Chịu trách nhiệm chính trong việc thiết lập hệ thống phòng thủ, cài đặt các bản vá lỗi cho cả 2 hệ thống FTP. | Đặng Trần Hải Đăng | 11/10/2026 |
| 3 | - Phân tích chi tiết CVE-2024-4040.<br>- Chịu trách nhiệm cài đặt phiên bản Wing FTP Server bị lỗi và chạy mã PoC khai thác lỗ hổng này trong Demo. Thu thập log và đánh giá rủi ro. | Trần Quốc Khánh | 11/10/2026 |
| 4 | - Phân tích chi tiết CVE-2025-54309.<br>- Chịu trách nhiệm cài đặt CrushFTP và thực hiện khai thác lỗ hổng bypass xác thực trong Demo. | Trần Huy Hoàng | 11/10/2026 |
| 5 | - Tổng hợp báo cáo, vẽ sơ đồ cấu hình mạng bằng phần mềm.<br>- Thu thập ảnh chụp màn hình minh chứng cho Demo. Đảm bảo form mẫu báo cáo chuẩn chỉ. | Nguyễn Thị Ngọc Anh | 11/10/2026 |

**NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ**

| TT | SV thực hiện | Thái độ tham gia | Mức hoàn thành CV | Kỹ năng giao tiếp | Kỹ năng hợp tác | Kỹ năng lãnh đạo |
|---|---|---|---|---|---|---|
| 1 | Ngô Quý Trường Giang | 5 | 5 | 5 | 5 | 5 |
| 2 | Trần Quốc Khánh | 5 | 5 | 5 | 5 | |
| 3 | Trần Huy Hoàng | 5 | 5 | 5 | 5 | |
| 4 | Nguyễn Thị Ngọc Anh | 5 | 5 | 5 | 5 | |
| 5 | Đặng Trần Hải Đăng | 5 | 5 | 5 | 5 | |

*Ghi chú*:

Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).

Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).

Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).

Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột

Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

## KẾ HOẠCH THỰC HIỆN THEO TUẦN

| Tuần | Mục tiêu | Nội dung chi tiết |
|---|---|---|
| 1 | Lên kế hoạch và khảo sát | - Lên kế hoạch, thiết kế cấu hình mạng mô phỏng.<br>- Khảo sát và thống nhất chọn 2 CVE mới: CVE-2024-4040 và CVE-2025-54309 để làm kịch bản tấn công. |
| 2 | Cấu hình | - Dựng môi trường Lab ảo.<br>- Cài đặt Firewall phân tách 3 vùng WAN, DMZ, LAN.<br>- Cài đặt Kali Linux (Attacker) và các máy chủ mục tiêu chạy Wing FTP Server và CrushFTP. |
| 3 | Triển khai 2 CVE | - Rà quét lỗ hổng.<br>- Triển khai mã khai thác đối với CVE-2024-4040 và khai thác bypass xác thực đối với CVE-2025-54309 để giành quyền điều khiển trên máy mục tiêu |
| 4 | Triển khai giải pháp phòng thủ | Thực hiện quy trình quản lý bản vá theo 6 bước: Discovery, Assessment, Acquisition, Testing, Deployment, Validation để đóng 2 lỗ hổng CVE. |
| 5 | Kiểm thử sơ bộ và viết báo cáo | - Kiểm tra toàn bộ hệ thống.<br>- Viết báo cáo tổng kết, đánh giá rủi ro và làm slide thuyết trình. |
| 6 | Báo cáo và Demo | - Trình bày Slide trước hội đồng.<br>- Thực hiện Demo thực tế 2 CVE.<br>- Chỉnh sửa báo cáo theo góp ý của giảng viên. |

# MỤC LỤC

MỤC LỤC ..... 5
DANH MỤC CÁC HÌNH VẼ ..... 7
DANH MỤC CÁC BẢNG BIỂU ..... 7
DANH MỤC CÁC TỪ VIẾT TẮT ..... 8
**CHƯƠNG 1.** GIỚI THIỆU VÀ CƠ SỞ LÝ THUYẾT ..... 9
1.1 Tổng quan về dịch vụ truyền nhận tệp ..... 9
1.2 Kiến trúc và cơ chế hoạt động của giao thức FTP ..... 9
**1.2.1** Cơ chế phân tách hai kênh kết nối ..... 9
**1.2.2** Chế độ hoạt động chủ động và bị động ..... 9
1.3 Điểm yếu trên giao thức FTP ..... 10
**1.3.1** Truyền thông với dữ liệu dưới dạng văn bản rõ ..... 10
**1.3.2** Lỗ hổng từ tài khoản ẩn danh ..... 11
1.4 Giải pháp truyền tệp an toàn ..... 11
**1.4.1** Giao thức truyền tệp FTPS ..... 11
**1.4.2** Giao thức truyền tệp SFTP ..... 11
**CHƯƠNG 2.** PHÂN TÍCH LỖ HỔNG VÀ ĐÁNH GIÁ RỦI RO AN TOÀN MẠNG ..... 13
2.1 Bề mặt tấn công hệ thống truyền nhận tệp ..... 13
**2.1.1** Tầng mạng và giao thức ..... 13
**2.1.2** Tầng ứng dụng máy chủ ..... 13
**2.1.3** Tấn công quyền hạn và cấu hình hệ thống ..... 13
2.2 Rủi ro của dữ liệu truyền không mã hóa ..... 13
2.3 Giới thiệu CrushFTP và các lỗ hổng bảo mật liên quan ..... 13
**2.3.1** Lỗ hổng Server-Side Template Injection trên CrushFTP ..... 14
**2.3.2** Lỗ hổng xác thực AS2 trên CrushFTP ..... 14
**CHƯƠNG 3.** KỊCH BẢN THỰC NGHIỆM VÀ TRIỂN KHAI PHÒNG THỦ ..... 15
3.1 Các kịch bản tấn công ..... 15
**3.1.1** Bắt gói tin và trích xuất dữ liệu ..... 15
**3.1.2** Khai thác lỗ hổng chèn mẫu đọc tệp tùy ý CVE-2024-4040 ..... 15
**3.1.3** Khai thác lỗ hổng chiếm quyền quản trị CVE-2025-54309 ..... 16
3.2 Triển khai giải pháp phòng thủ ..... 16
**3.2.1** Kiểm chứng mã hóa bằng Wireshark ..... 17
**3.2.2** Phân vùng mạng qua tường lửa pfSense ..... 17
**CHƯƠNG 4.** KIỂM TRA ĐÁNH GIÁ ..... 20

4.1 Đánh giá và so sánh giải pháp ..... 20
4.2 Bài học kinh nghiệm thực tiễn ..... 20
4.3 Hướng phát triển và mở rộng ..... 20
4.4 Đánh giá về tuân thủ đạo đức ..... 21
TÀI LIỆU THAM KHẢO ..... 22

# DANH MỤC CÁC HÌNH VẼ

Hình 1 Kiến trúc kênh điều khiển và kênh dữ liệu của FTP ..... 9
Hình 2 Cơ chế kết nối dữ liệu trong chế độ chủ động ..... 10
Hình 3 Cơ chế kết nối dữ liệu trong chế độ bị động ..... 10
Hình 4 Kiến trúc bảo vệ dữ liệu của giao thức FTPS ..... 11
Hình 5 Kiến trúc truyền tệp an toàn của giao thức SFTP ..... 12
Hình 6 Thông tin tài khoản và nội dung tệp tin bản rõ trong luồng FTP ..... 15
Hình 7 Kết quả khai thác đọc tệp tin tùy ý qua lỗ hổng CVE-2024-4040 ..... 16
Hình 8 Kết quả vượt qua xác thực và trích xuất danh sách tài khoản qua CVE-2025-54309 ..... 16
Hình 9 Lưu lượng truyền tệp tin FTPS được mã hóa trong Wireshark ..... 17
Hình 10 Sơ đồ kiến trúc phân vùng mạng qua tường lửa pfSense ..... 18
Hình 11 Kết quả Wireshark chứng minh lưu lượng nội bộ không bị bắt giữ sau khi phân vùng mạng ..... 19

# DANH MỤC CÁC BẢNG BIỂU

Bảng 1. So sánh toàn diện ba phương thức truyền nhận tệp ..... 20

# DANH MỤC CÁC TỪ VIẾT TẮT

| Từ viết tắt | Thuật ngữ tiếng Anh/Giải thích | Thuật ngữ tiếng Việt/Giải thích |
|---|---|---|
| FTP | File Transfer Protocol | Giao thức truyền tệp tin mạng |
| FTPS | File Transfer Protocol Secure | Giao thức truyền tệp tin an toàn với TLS |
| SFTP | SSH File Transfer Protocol | Giao thức truyền tệp tin an toàn qua SSH |
| SSH | Secure Shell | Giao thức vỏ bảo mật điều khiển từ xa |
| TLS | Transport Layer Security | Giao thức bảo mật tầng giao vận |
| SSL | Secure Sockets Layer | Giao thức bảo mật lớp socket |
| TCP | Transmission Control Protocol | Giao thức điều khiển truyền vận |
| IP | Internet Protocol | Giao thức liên mạng |
| CVE | Common Vulnerabilities and Exposures | Danh mục lỗ hổng và phơi nhiễm phổ biến |
| CVSS | Common Vulnerability Scoring System | Hệ thống thang điểm đánh giá mức độ nghiêm trọng lỗ hổng |
| RFC | Request for Comments | Đề nghị thẩm tra nhận xét, tài liệu tiêu chuẩn Internet |
| SSTI | Server-Side Template Injection | Kỹ thuật tấn công chèn mẫu từ phía máy chủ |
| AS2 | Applicability Statement 2 | Tiêu chuẩn trao đổi dữ liệu kinh doanh điện tử an toàn |
| LAN | Local Area Network | Mạng cục bộ |
| WAN | Wide Area Network | Mạng diện rộng |
| NAT | Network Address Translation | Biên dịch địa chỉ mạng |

# CHƯƠNG 1. GIỚI THIỆU VÀ CƠ SỞ LÝ THUYẾT

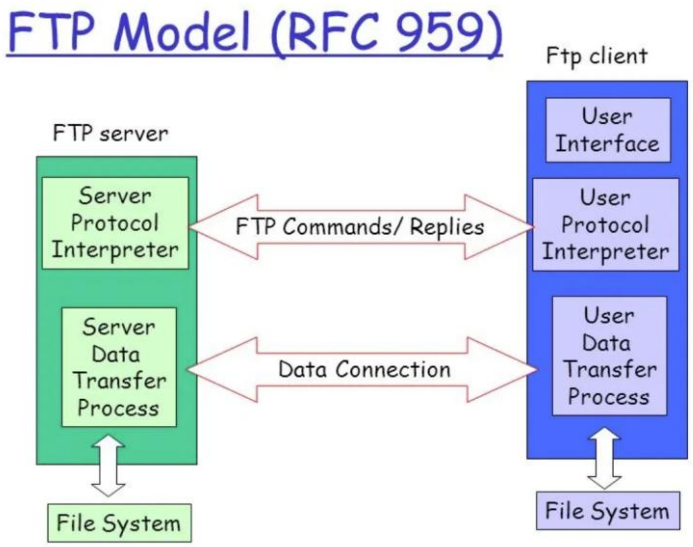
## 1.1 Tổng quan về dịch vụ truyền nhận tệp

Dịch vụ truyền nhận tệp là một dịch vụ mạng cốt lõi thuộc tầng ứng dụng, cho phép người dùng và các tiến trình tự động thực hiện việc truyền tải, quản lý, sao lưu hoặc di chuyển dữ liệu có cấu trúc giữa các hệ thống máy tính qua môi trường mạng. Để đảm bảo tính toàn vẹn và chính xác tuyệt đối của dữ liệu, dịch vụ này luôn dựa trên nền tảng tin cậy của tầng giao vận như giao thức TCP với cơ chế bắt tay ba bước và kiểm soát lỗi. Tuy nhiên, trong bối cảnh công nghệ và an toàn mạng hiện đại, việc sử dụng các giao thức truyền tệp truyền thống đã được nâng cấp hoặc thay thế bằng các giải pháp mã hóa bảo mật như SFTP hay FTPS nhằm ngăn chặn các nguy cơ rò rỉ thông tin nhạy cảm và đáp ứng các tiêu chuẩn an toàn thông tin khắt khe trong doanh nghiệp.

## 1.2 Kiến trúc và cơ chế hoạt động của giao thức FTP

### *1.2.1 Cơ chế phân tách hai kênh kết nối*

Kiến trúc của giao thức truyền tệp tin truyền thống sử dụng hai kết nối mạng riêng biệt hoạt động song song trong suốt một phiên làm việc của người dùng. FTP sử dụng kiến trúc hai kênh kết nối riêng biệt hoạt động song song trong suốt phiên làm việc. Kênh điều khiển được thiết lập từ một cổng ngẫu nhiên của máy khách đến cổng 21 tiêu chuẩn của máy chủ, được duy trì liên tục để truyền các lệnh văn bản và nhận mã trạng thái phản hồi, hoàn toàn không truyền tải dữ liệu tệp tin. Ngược lại, kênh dữ liệu được tạo mới một cách linh hoạt cho từng thao tác truyền tải tệp hoặc liệt kê thư mục, và sẽ tự động đóng lại ngay sau khi hoàn tất khối dữ liệu để tối ưu hóa tài nguyên mạng.

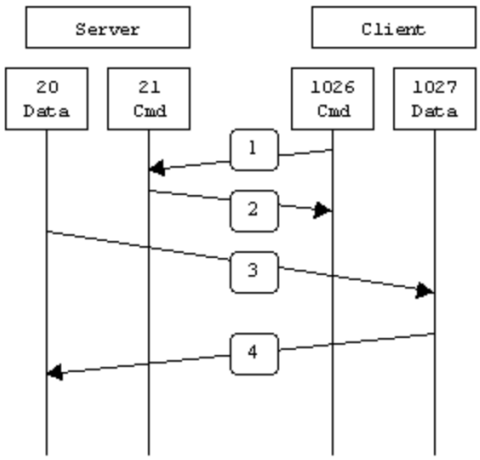



*Hình 1 Kiến trúc kênh điều khiển và kênh dữ liệu của FTP*

### *1.2.2 Chế độ hoạt động chủ động và bị động*

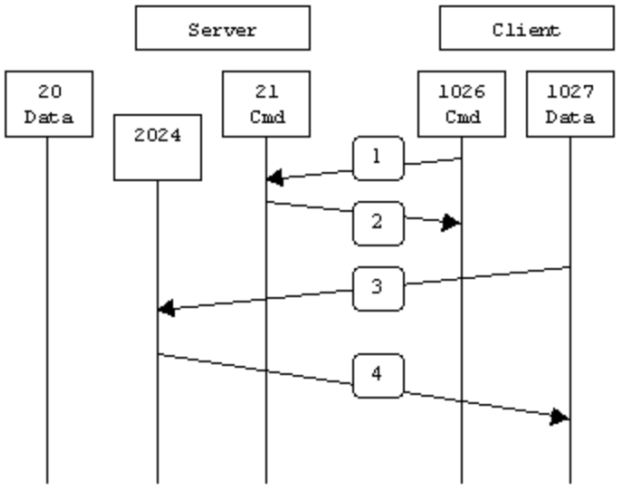
Trong chế độ chủ động – Active mode của FTP, máy khách thông báo cho máy chủ một cổng ngẫu nhiên thông qua kênh điều khiển, để rồi máy chủ chủ động khởi tạo kết nối dữ

liệu ngược lại từ cổng 20 của mình đến cổng đó của máy khách. Tuy nhiên, điểm yếu mấu chốt của chế độ này là khi máy khách nằm sau tường lửa hoặc thiết bị NAT, các kết nối chủ động từ ngoài Internet đi vào sẽ bị chặn đứng, khiến việc thiết lập kênh dữ liệu và truyền tải tệp tin thất bại hoàn toàn.




*Hình 2 Cơ chế kết nối dữ liệu trong chế độ chủ động*

Để khắc phục hạn chế của chế độ chủ động, chế độ bị động – Passive mode cho phép toàn bộ kết nối đều do máy khách chủ động khởi tạo từ trong mạng nội bộ đi ra. Sau khi nhận lệnh chuyển đổi qua kênh điều khiển, máy chủ sẽ mở một cổng ngẫu nhiên và gửi thông tin về cho máy khách tự thiết lập kết nối dữ liệu tới đó. Cơ chế này giúp máy khách dễ dàng vượt qua tường lửa, nhưng đồng thời đòi hỏi máy chủ phải mở một dải cổng lớn và cấu hình xử lý địa chỉ mạng phức tạp nếu bản thân máy chủ đặt sau thiết bị NAT.




*Hình 3 Cơ chế kết nối dữ liệu trong chế độ bị động*

## 1.3 Điểm yếu trên giao thức FTP

Mặc dù đóng vai trò nền tảng trong nhiều thập kỷ, giao thức truyền tệp tin truyền thống chứa đựng những lỗ hổng bảo mật nghiêm trọng không thể khắc phục nếu không thay đổi bản chất giao thức.

### *1.3.1 Truyền thông với dữ liệu dưới dạng văn bản rõ*

Do được thiết kế từ năm 1985 khi các mối đe dọa an ninh mạng chưa được chú trọng đúng mức, FTP truyền tải toàn bộ thông điệp trên cả kênh điều khiển lẫn kênh dữ liệu dưới dạng văn bản rõ không mã hóa. Cả thông tin định danh, mật khẩu xác thực lẫn nội dung tệp tin đều hiển thị nguyên vẹn, khiến hệ thống dễ dàng bị kẻ tấn công trên cùng phân đoạn mạng hoặc thiết bị trung chuyển bắt giữ và đánh cắp thông tin nhạy cảm.

### *1.3.2 Lỗ hổng từ tài khoản ẩn danh*

Giao thức cung cấp tính năng cho phép người dùng đăng nhập bằng tên tài khoản ẩn danh để truy cập các tài nguyên chia sẻ công cộng mà không cần tạo tài khoản định danh riêng biệt. Tuy nhiên, trong thực tế quản trị hệ thống, việc cấu hình sai quyền hạn cho tài khoản này diễn ra rất phổ biến. Khi tài khoản ẩn danh vô tình được cấp quyền ghi hoặc quyền tạo thư mục, kẻ xấu có thể sử dụng máy chủ làm kho chứa mã độc, trung chuyển dữ liệu đánh cắp hoặc làm cạn kiệt dung lượng đĩa cứng của máy chủ.

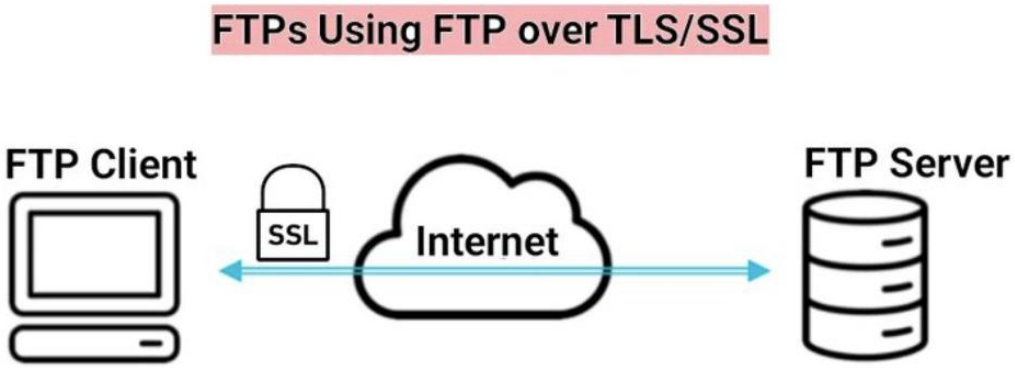
## 1.4 Giải pháp truyền tệp an toàn

Để giải quyết triệt để vấn đề mất an toàn của giao thức truyền thống, hai giải pháp công nghệ chính đã được chuẩn hóa và áp dụng rộng rãi trong các hệ thống mạng doanh nghiệp hiện đại.

### *1.4.1 Giao thức truyền tệp FTPS*

Về bản chất, giải pháp này giữ nguyên mô hình hai kênh kết nối của giao thức truyền thống nhưng tích hợp thêm lớp bảo mật giao vận để thiết lập cơ chế mật mã bảo vệ.

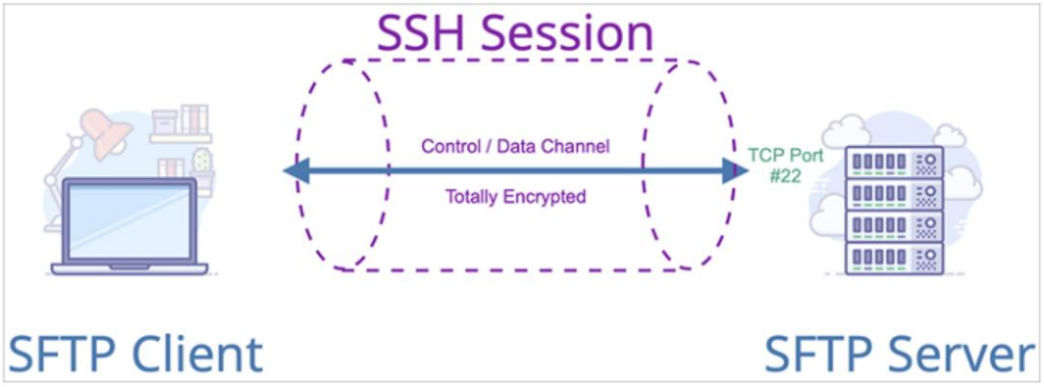
Giao thức FTPS giữ nguyên mô hình hai kênh kết nối của FTP truyền thống nhưng tích hợp thêm lớp bảo mật SSL/TLS để bảo vệ dữ liệu. FTPS hỗ trợ hai chế độ triển khai: chế độ tường minh - Explicit yêu cầu máy khách kết nối qua cổng tiêu chuẩn 21 rồi ra lệnh kích hoạt mã hóa, trong khi chế độ ngầm định - Implicit bắt buộc thực hiện bắt tay mã hóa ngay từ đầu qua cổng riêng biệt 990. Thông qua việc sử dụng chứng thư số công cộng để xác thực máy chủ, FTPS đảm bảo tính bí mật và toàn vẹn tuyệt đối cho cả kênh điều khiển lẫn kênh dữ liệu.




*Hình 4 Kiến trúc bảo vệ dữ liệu của giao thức FTPS*

### *1.4.2 Giao thức truyền tệp SFTP*

Khác biệt hoàn toàn với FTP và FTPS, giao thức SFTP được thiết kế như một phần mở rộng của giao thức SSH theo chuẩn RFC 4253. SFTP chỉ sử dụng duy nhất một kết nối mạng trên cổng 22 cho toàn bộ quá trình xác thực, điều khiển và truyền tải tệp tin. Toàn bộ gói tin đều được mã hóa đối xứng mạnh mẽ, tích hợp cơ chế xác thực toàn vẹn bằng mã thông điệp và hỗ trợ xác thực linh hoạt qua mật khẩu hoặc cặp khóa công khai - bí mật, giúp giải pháp này vừa bảo mật tuyệt đối vừa vô cùng thân thiện với các quy tắc tường lửa và thiết bị NAT.




*Hình 5 Kiến trúc truyền tệp an toàn của giao thức SFTP*

# CHƯƠNG 2. PHÂN TÍCH LỖ HỔNG VÀ ĐÁNH GIÁ RỦI RO AN TOÀN MẠNG

## 2.1 Bề mặt tấn công hệ thống truyền nhận tệp

Để xây dựng một chiến lược bảo vệ hệ thống hiệu quả, việc nhận diện và phân tích toàn diện bề mặt tấn công của dịch vụ truyền tệp tin là bước đi tiên quyết. Bề mặt tấn công của dịch vụ này được cấu thành từ ba tầng kiến trúc chính.

### *2.1.1 Tầng mạng và giao thức*

Bề mặt tấn công tầng mạng tập trung vào các điểm yếu trong quá trình lưu chuyển gói tin trên môi trường truyền dẫn. Đối với các giao thức không mã hóa, bề mặt tấn công bao gồm các kỹ thuật nghe lén bị động trên các cổng kết nối mạng chia sẻ, kỹ thuật đầu độc bảng phân giải địa chỉ phần cứng để chuyển hướng luồng dữ liệu qua máy tính của kẻ tấn công, và kỹ thuật tấn công xen giữa để can thiệp, sửa đổi nội dung tệp tin hoặc chiếm đoạt phiên làm việc ngay sau khi người dùng hoàn tất xác thực.

### *2.1.2 Tầng ứng dụng máy chủ*

Bề mặt tấn công tầng ứng dụng xuất phát từ chính mã nguồn và các tính năng mở rộng của phần mềm máy chủ. Đối với phần mềm máy chủ đa giao thức như CrushFTP, giao diện quản trị qua nền tảng web chạy trên cổng TCP 8080 chính là bề mặt tấn công có nguy cơ bị xâm nhập cao nhất. Các lỗ hổng lập trình như chèn mẫu từ phía máy chủ CVE-2024-4040 hay lỗi tương tranh phiên làm việc CVE-2025-54309 đều phát sinh trên tầng ứng dụng này, cho phép đối tượng tấn công từ xa thực hiện các thao tác đọc tệp tin tùy ý hoặc chiếm quyền quản trị tối cao của dịch vụ.

### *2.1.3 Tấn công quyền hạn và cấu hình hệ thống*

Bề mặt tấn công tầng cấu hình hệ thống liên quan đến việc thiết lập chính sách bảo mật của người quản trị máy chủ. Nếu máy chủ không áp dụng cơ chế giam giữ thư mục gốc một cách chặt chẽ, người dùng sau khi xác thực có thể thực hiện tấn công duyệt cây thư mục bằng các chuỗi đường dẫn tương đối để thoát khỏi phạm vi thư mục được phân quyền, từ đó đọc hoặc ghi đè lên các tệp tin cấu hình nhạy cảm của hệ điều hành. Ngoài ra, việc duy trì mật khẩu mặc định, cấp quyền ghi quá rộng hoặc bật tính năng đăng nhập ẩn danh cũng tạo ra những điểm hở nghiêm trọng trong phòng thủ.

## 2.2 Rủi ro của dữ liệu truyền không mã hóa

Để minh chứng cho các rủi ro lý thuyết, nhóm đã tiến hành kiểm thử bắt gói tin thực tế bằng Wireshark, qua đó phơi bày mức độ bảo mật thấp của FTP truyền thống. Trên kênh điều khiển, thông tin tên đăng nhập và mật khẩu xuất hiện hoàn toàn dưới dạng văn bản rõ, cho phép kẻ tấn công dễ dàng thu thập mà không cần giải mã. Đồng thời, trên kênh dữ liệu, các khối tệp tin truyền đi dưới dạng nhị phân thô cũng bị ghi lại và khôi phục nguyên vẹn cấu trúc gốc, khẳng định sự cần thiết cấp bách phải chuyển đổi sang các giao thức mã hóa như SFTP hay FTPS.

## 2.3 Giới thiệu CrushFTP và các lỗ hổng bảo mật liên quan

CrushFTP là phần mềm máy chủ truyền nhận tệp đa giao thức, cung cấp tính năng quản lý người dùng, phân quyền qua giao diện web và đóng vai trò tiếp nhận, xử lý dữ liệu trọng yếu của doanh nghiệp. Chính vì vậy CrushFTP trở thành mục tiêu tấn công khai thác điểm yếu phần mềm hoặc xác thực. Để làm rõ các nguy cơ ở tầng ứng dụng, nhóm sẽ tập trung phân tích hai lỗ hổng nghiêm trọng bao gồm CVE-2024-4040 lỗi xử lý mẫu phía máy chủ - SSTI và CVE-2025-54309 lỗi cơ chế xác thực AS2, qua đó đánh giá mức độ ảnh hưởng trực tiếp đến tính bí mật dữ liệu và quyền quản trị hệ thống.

### *2.3.1 Lỗ hổng Server-Side Template Injection trên CrushFTP*

CVE-2024-4040 là lỗ hổng Server-Side Template Injection nghiêm trọng trên các phiên bản CrushFTP cũ trước 10.7.1 và 11.1.0. Lỗ hổng cho phép kẻ tấn công chưa xác thực đọc tệp ngoài phạm vi VFS Sandbox, vượt qua cơ chế xác thực quản trị và thực thi mã từ xa. Nguyên nhân xuất phát từ việc dữ liệu đầu vào không được kiểm định, bị hệ thống xử lý nhầm thành cú pháp thực thi. Điều này cho thấy lỗi xử lý đầu vào có thể làm suy yếu phân vùng dữ liệu tầng ứng dụng, đòi hỏi phải cập nhật bản vá và thắt chặt kiểm soát truy cập..

### *2.3.2 Lỗ hổng xác thực AS2 trên CrushFTP*

CVE-2025-54309 là lỗ hổng xác thực giao thức AS2 nghiêm trọng trên các phiên bản CrushFTP 10 trước 10.8.5 khi cấu hình thiếu DMZ Proxy. Điểm yếu trong logic kiểm tra xác thực cho phép kẻ tấn công từ xa qua HTTPS vượt qua hệ thống để chiếm quyền quản trị mà không cần tài khoản hợp lệ. Điều này chứng minh rằng việc mã hóa đường truyền bằng HTTPS không thể thay thế cho việc bảo mật logic xác thực, đòi hỏi phải rà soát cấu hình và cập nhật bản vá khẩn cấp.

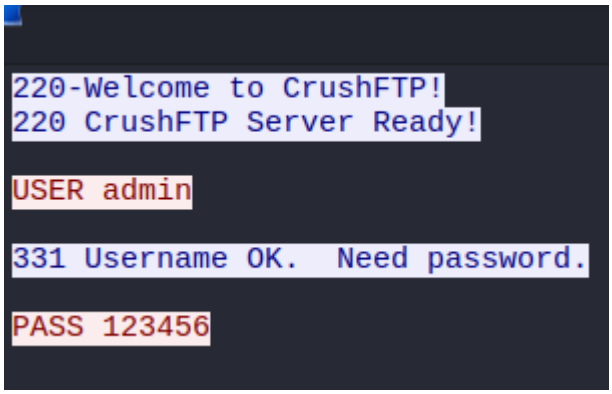
# CHƯƠNG 3. KỊCH BẢN THỰC NGHIỆM VÀ TRIỂN KHAI PHÒNG THỦ

## 3.1 Các kịch bản tấn công

Nhóm tiến hành thực nghiệm các đòn tấn công nhằm chứng minh các bề mặt rủi ro đã phân tích ở chương trước, bao gồm việc nghe lén dữ liệu bản rõ trên giao thức truyền thống và khai thác hai lỗ hổng bảo mật nghiêm trọng trên tầng ứng dụng của máy chủ CrushFTP. Toàn bộ các bước kiểm thử đều được ghi nhận bằng hình ảnh kết quả cuối cùng để đối chiếu tính xác thực.

### *3.1.1 Bắt gói tin và trích xuất dữ liệu*

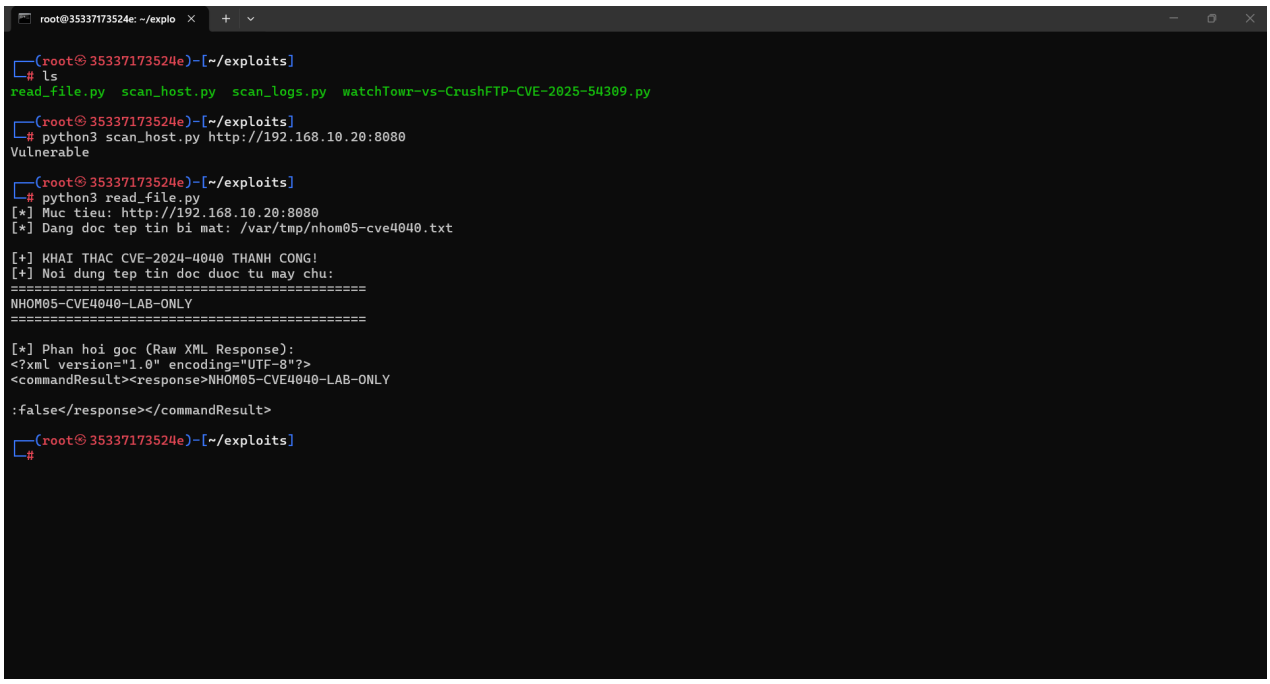
Trong kịch bản đầu tiên, máy khách thực hiện kết nối và tải tệp tin mau.txt từ máy chủ thông qua giao thức truyền thống trên cổng TCP 21. Quá trình bắt gói tin bằng công cụ Wireshark trên môi trường mạng phẳng ghi nhận toàn bộ lưu lượng phát sinh trong phiên giao tiếp. Khi sử dụng tính năng theo dõi luồng TCP, hệ thống phơi bày nguyên vẹn tên tài khoản người dùng, mật khẩu xác thực và toàn bộ nội dung văn bản của tệp tin truyền trên đường truyền dưới dạng bản rõ hoàn toàn mà không có bất kỳ thuật toán mã hóa nào bảo vệ.




*Hình 6 Thông tin tài khoản và nội dung tệp tin bản rõ trong luồng FTP*

### *3.1.2 Khai thác lỗ hổng chèn mẫu đọc tệp tùy ý CVE-2024-4040*

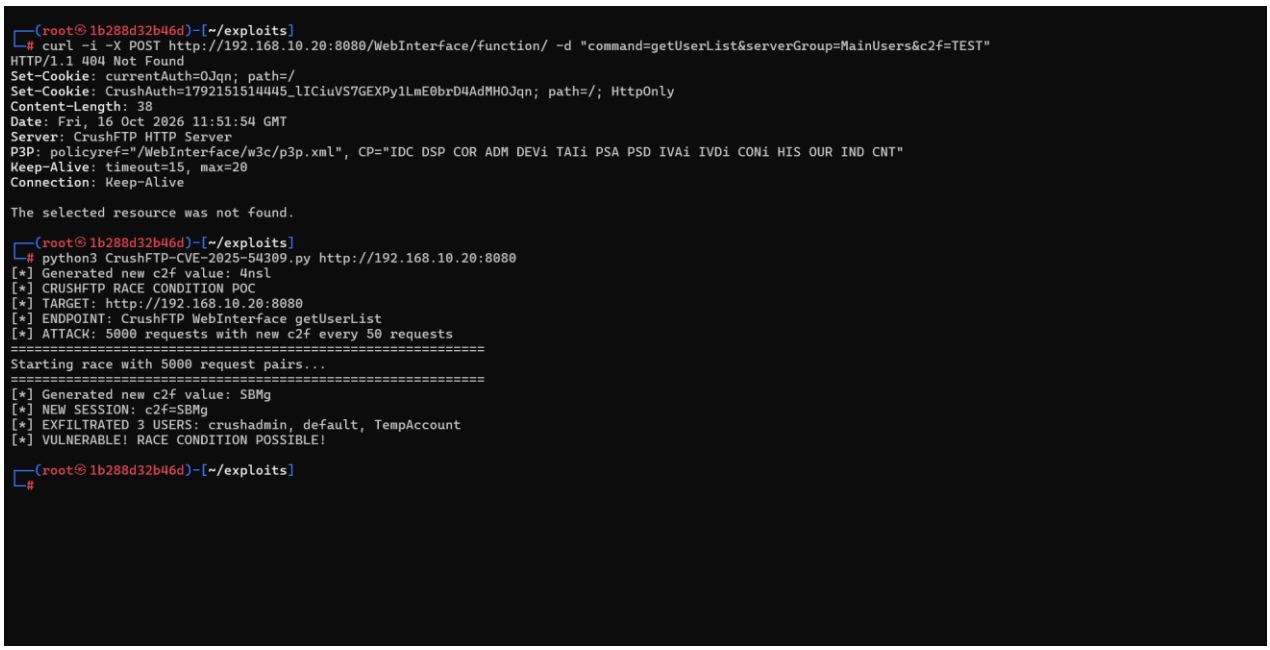
Trong kịch bản thứ hai, nhóm thực hiện tấn công khai thác lỗ hổng chèn mẫu từ phía máy chủ Server-Side Template Injection trên giao diện web cổng TCP 8080 của máy chủ CrushFTP phiên bản 10.6.0_0. Kẻ tấn công gửi các yêu cầu HTTP chứa thẻ mẫu đặc biệt mà không cần xác thực danh tính. Máy chủ bị thao túng logic xử lý và đọc thành công nội dung của tệp tin đánh dấu bí mật nằm ngoài phạm vi thư mục được phân quyền tại đường dẫn /var/tmp/nhom05-cve4040.txt, chứng minh nguy cơ thất thoát dữ liệu nhạy cảm trên hệ điều hành máy chủ.




*Hình 7 Kết quả khai thác đọc tệp tin tùy ý qua lỗ hổng CVE-2024-4040*

### *3.1.3 Khai thác lỗ hổng chiếm quyền quản trị CVE-2025-54309*

Trong kịch bản thứ ba, nhóm tiến hành tấn công lợi dụng điều kiện tương tranh trong cơ chế xử lý phiên làm việc của giao thức trao đổi dữ liệu AS2 trên máy chủ CrushFTP. Bằng cách gửi liên tục các yêu cầu đồng thời trong khoảng thời gian cực ngắn, cơ chế đồng bộ hóa bị lỗi logic và cấp phiên làm việc với đặc quyền quản trị cho máy kiểm thử. Từ phiên làm việc này, máy kiểm thử thực hiện trích xuất thành công toàn bộ danh sách tài khoản người dùng hệ thống mà không cần cung cấp mật khẩu quản trị viên.




*Hình 8 Kết quả vượt qua xác thực và trích xuất danh sách tài khoản qua CVE-2025-54309*

## 3.2 Triển khai giải pháp phòng thủ

Để loại bỏ triệt để các rủi ro đã được kiểm chứng thực tế, nhóm triển khai hai lớp phòng thủ cốt lõi: phòng thủ tầng kênh truyền bằng các giao thức mã hóa mạnh mẽ, và phòng thủ tầng hạ tầng thông qua việc phân vùng mạng và kiểm soát lưu lượng bằng tường lửa pfSense.

### *3.2.1 Kiểm chứng mã hóa bằng Wireshark*

Nhóm tiến hành cấu hình kích hoạt giao thức FTPS tường minh trên cổng tiêu chuẩn 21 của máy chủ CrushFTP có xác thực chứng thư số, đồng thời triển khai dịch vụ SFTP chạy trên nền tảng vỏ bảo mật OpenSSH tại cổng TCP 22. Khi thực hiện lại các phiên truyền tệp tin qua FTPS và SFTP, toàn bộ dữ liệu điều khiển và nội dung tệp tin đều được đóng gói an toàn trong các bản tin mã hóa.

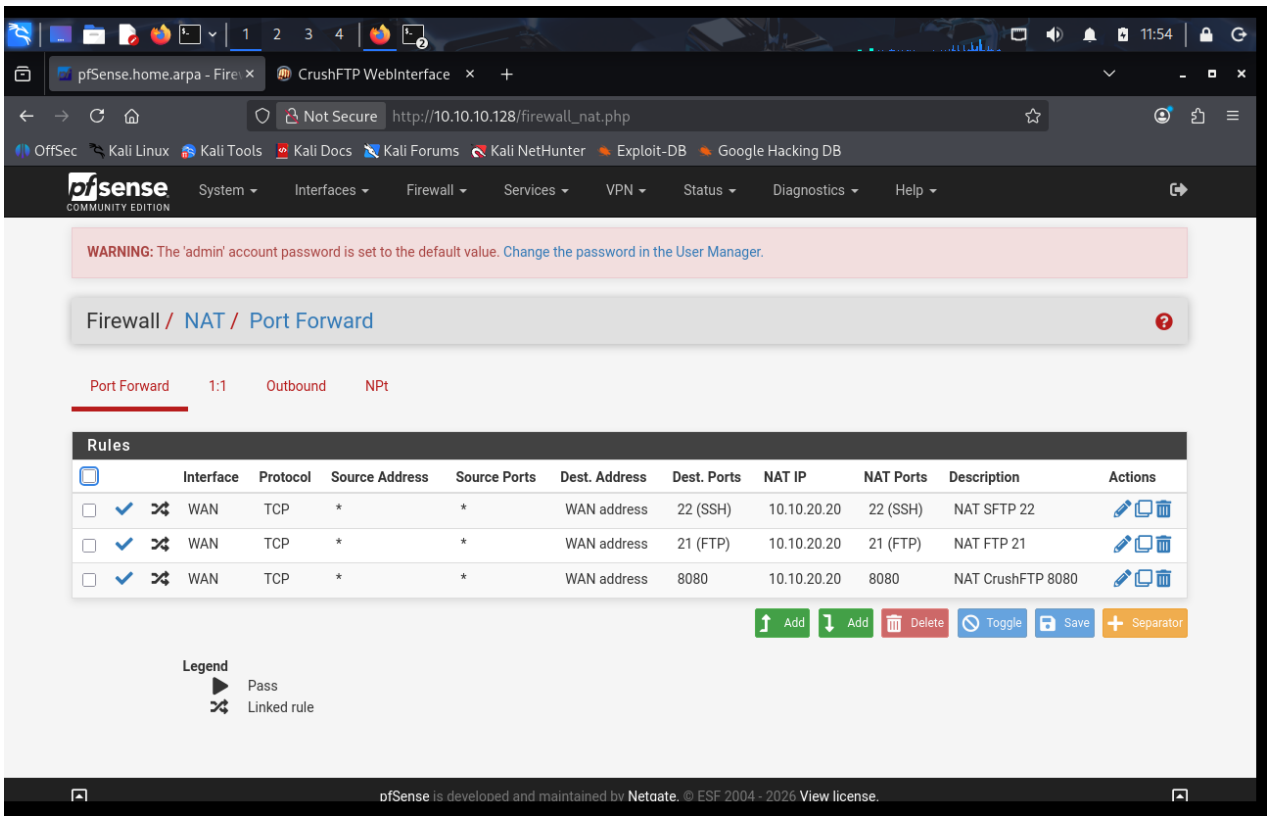
Quá trình bắt gói tin kiểm tra lại bằng công cụ Wireshark đối với phiên truyền FTPS cho thấy toàn bộ thông tin đăng nhập và luồng truyền dữ liệu tệp tin đều được bảo vệ bởi lớp bảo mật giao vận TLS. Kẻ nghe lén trên đường truyền chỉ thu được các khối dữ liệu ứng dụng mã hóa nhị phân mà không thể trích xuất được bất kỳ thông tin nào.




*Hình 9 Lưu lượng truyền tệp tin FTPS được mã hóa trong Wireshark*

### *3.2.2 Phân vùng mạng qua tường lửa pfSense*

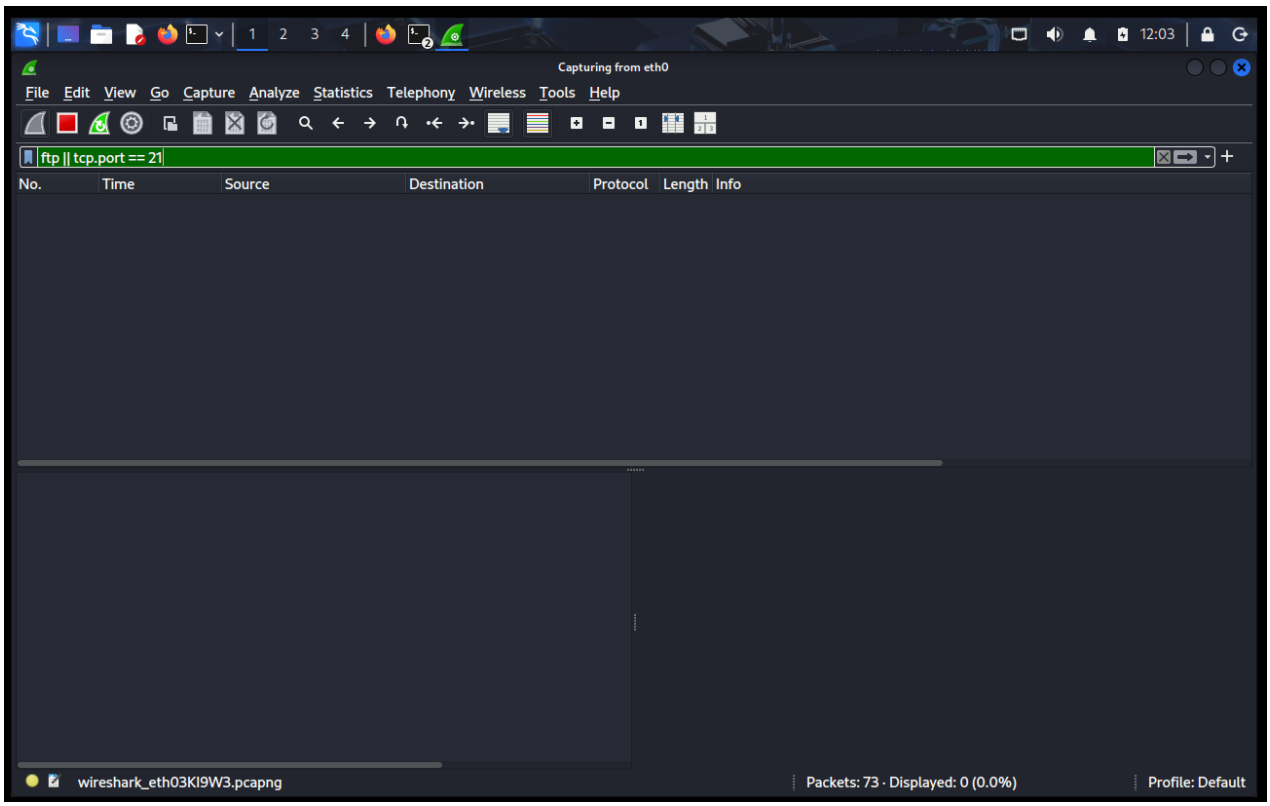
Bên cạnh việc mã hóa đường truyền, nhóm tiến hành nâng cấp kiến trúc mạng từ mạng phẳng sang mạng phân vùng an ninh đa tầng bằng cách đặt tường lửa pfSense làm chốt chặn trung tâm. Hệ thống được chia tách thành vùng mạng diện rộng bên ngoài WAN chứa máy kiểm thử Kali Linux với dải địa chỉ 10.10.10.0/24 và vùng mạng nội bộ LAN chứa máy chủ Ubuntu Server với dải địa chỉ 10.10.20.0/24. Tường lửa áp dụng bộ quy tắc lọc gói nghiêm ngặt, chỉ cho phép các cổng dịch vụ cần thiết đi qua và cô lập hoàn toàn lưu lượng truyền nội bộ của vùng mạng LAN.




*Hình 10 Sơ đồ kiến trúc phân vùng mạng qua tường lửa pfSense*

Để kiểm chứng hiệu quả của việc phân vùng mạng, máy kiểm thử ở vùng mạng ngoài WAN kích hoạt công cụ Wireshark nhằm cố gắng nghe lén luồng truyền tệp tin diễn ra trong vùng mạng nội bộ LAN. Kết quả bắt gói tin trên giao diện mạng của máy kiểm thử cho thấy hoàn toàn không thể thu thập được bất kỳ gói tin nào của các phiên truyền nhận trong mạng LAN. Tường lửa pfSense đã ngăn chặn triệt để hiện tượng tràn gói tin và cô lập tuyệt đối lưu lượng giữa các phân đoạn mạng độc lập.

```
atm@btlatm:~$ sudo /var/opt/CrushFTP10/crushftp_init.sh start
CrushFTP is not currently running...
Starting CrushFTP... OK
atm@btlatm:~$ ftp 10.10.20.20
Connected to 10.10.20.20.
220-Welcome to CrushFTP!
220 CrushFTP Server Ready!
Name (10.10.20.20:atm): crushadmin
550-This server requires encryption.
550 You must issue the AUTH command to change to an encrypted session before you can attempt to login.
ftp: Login failed
ftp> ls
421 Service not available, remote server has closed connection.
550-This server requires encryption.
ftp> quit
atm@btlatm:~$ curl -v -u crushadmin:admin123 ftp://10.10.20.20/mau.txt -o /tmp/test.txt
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
  0     0    0     0    0     0      0      0 --:--:-- --:--:-- --:--:--     0*   Trying 10.10.20.20:21...
* Connected to 10.10.20.20 (10.10.20.20) port 21
< 220-Welcome to CrushFTP!
< 220 CrushFTP Server Ready!
> USER crushadmin
< 550-This server requires encryption.
< 550 You must issue the AUTH command to change to an encrypted session before you can attempt to login.
* Access denied: 550
  0     0    0     0    0     0      0      0 --:--:-- --:--:-- --:--:--     0
* Closing connection
curl: (67) Access denied: 550
atm@btlatm:~$
```




*Hình 11 Kết quả Wireshark chứng minh lưu lượng nội bộ không bị bắt giữ sau khi phân vùng mạng*

# CHƯƠNG 4. KIỂM TRA ĐÁNH GIÁ

## 4.1 Đánh giá và so sánh giải pháp

Thông qua quá trình nghiên cứu lý thuyết và thực nghiệm chuyên sâu, nhóm tổng hợp bảng so sánh đối chiếu toàn diện giữa ba phương thức truyền tệp tin phổ biến.

*Bảng 1. So sánh toàn diện ba phương thức truyền nhận tệp*

| **Tiêu chí đánh giá** | **FTP truyền thống** | **FTPS** | **SFTP** |
|---|---|---|---|
| Mã hóa đường truyền | Không có mã hóa | Mã hóa bằng TLS | Mã hóa bằng SSH |
| Bảo vệ thông tin đăng nhập | Bản rõ hoàn toàn | Được bảo vệ bằng TLS | Được bảo vệ bằng SSH |
| Bảo vệ nội dung tệp tin | Bản rõ hoàn toàn | Được bảo vệ bằng TLS | Được bảo vệ bằng SSH |
| Số lượng cổng kết nối | Hai kênh gồm TCP 21 và cổng động | Hai kênh gồm TCP 21 và dải passive | Một kênh duy nhất trên TCP 22 |
| Tương thích tường lửa và NAT | Kém, dễ xung đột kênh dữ liệu | Trung bình, cần mở dải cổng passive | Rất tốt, cấu hình đơn giản |
| Xác thực người dùng | Mật khẩu đơn giản | Mật khẩu và chứng thư số | Mật khẩu và cặp khóa công khai |

## 4.2 Bài học kinh nghiệm thực tiễn

Kết quả bài tập lớn mang lại nhiều bài học kinh nghiệm sâu sắc trong công tác thiết kế và quản trị an toàn hệ thống mạng. Bài học quan trọng nhất là nguyên tắc phòng thủ đa lớp. Việc chỉ mã hóa đường truyền bằng FTPS hoặc SFTP là điều kiện cần thiết để chống lại nguy cơ nghe lén trên mạng, nhưng chưa đủ để bảo vệ an toàn cho dữ liệu nếu máy chủ ứng dụng vẫn còn tồn tại các lỗ hổng lập trình nghiêm trọng như CVE-2024-4040. Kẻ tấn công vẫn có thể chiếm đoạt dữ liệu thông qua giao diện web mà không cần bẻ khóa đường truyền mã hóa.

Do đó, một chiến lược an toàn mạng toàn diện đòi hỏi phải kết hợp nhuần nhuyễn giữa việc áp dụng các giao thức mã hóa mạnh mẽ, duy trì quy trình quản lý cập nhật bản vá bảo mật thường xuyên cho các phần mềm máy chủ, thực hiện phân quyền tối thiểu và cô lập môi trường người dùng bằng cơ chế giam giữ thư mục gốc, đồng thời thiết lập các chốt chặn tường lửa nghiêm ngặt để thu hẹp tối đa bề mặt tấn công của hệ thống.

## 4.3 Hướng phát triển và mở rộng

Trên cơ sở những kết quả đã đạt được, hệ thống có thể tiếp tục được nghiên cứu và phát triển theo các hướng mở rộng.

Thứ nhất, nâng cấp cơ chế xác thực của dịch vụ SFTP từ phương thức mật khẩu truyền thống sang phương thức xác thực bằng cặp khóa công khai và khóa bí mật kết hợp xác thực đa yếu tố, giúp loại bỏ hoàn toàn nguy cơ tấn công dò quét mật khẩu.

Thứ hai, tích hợp các hệ thống phát hiện và ngăn chặn xâm nhập mạng chuyên sâu như Snort hoặc Suricata trực tiếp trên tường lửa pfSense để tự động phân tích gói tin, nhận diện và ngăn chặn kịp thời các nỗ lực quét cổng hoặc khai thác các lỗ hổng ứng dụng web ngay từ cửa ngõ mạng.

### 4.4 Đánh giá về tuân thủ đạo đức

Trong quá trình thực hiện bài tập lớn, nhóm nhận thức được tầm quan trọng của đạo đức an toàn thông tin khi tiến hành kiểm thử và khai thác lỗ hổng bảo mật. Các hoạt động thực nghiệm như bắt gói tin bằng Wireshark, khai thác lỗ hổng CVE-2024-4040 và CVE-2025-54309 đều được thực hiện trong môi trường phòng lab phục vụ mục đích học tập, nghiên cứu và nâng cao kiến thức chuyên môn. Nhóm không sử dụng các kỹ thuật đã nghiên cứu để truy cập trái phép, đánh cắp dữ liệu hoặc gây ảnh hưởng đến các hệ thống ngoài phạm vi kiểm thử.

Bên cạnh đó, nhóm chú trọng bảo vệ thông tin thu thập được trong quá trình thực nghiệm, sử dụng dữ liệu kiểm thử phù hợp và ghi nhận trung thực kết quả tấn công cũng như hiệu quả của các biện pháp phòng thủ. Các lỗ hổng được khai thác nhằm chứng minh nguy cơ mất an toàn và làm cơ sở đề xuất giải pháp khắc phục, không nhằm mục đích phá hoại hay trục lợi cá nhân. Nhóm cũng nhận thức rằng việc phát hiện lỗ hổng cần đi kèm với trách nhiệm thông báo cho đơn vị quản lý hệ thống và không công khai thông tin có thể bị lợi dụng khi chưa phù hợp.

Qua bài tập lớn, nhóm hiểu rằng kiến thức và công cụ kiểm thử bảo mật cần được sử dụng đúng mục đích, có sự cho phép và tuân thủ quy định pháp luật. Ethical hacking không chỉ đòi hỏi năng lực kỹ thuật mà còn yêu cầu tính trung thực, trách nhiệm và tôn trọng quyền riêng tư. Đây là những nguyên tắc quan trọng để đảm bảo hoạt động kiểm thử góp phần nâng cao an toàn hệ thống thay vì tạo ra những rủi ro mới.

# TÀI LIỆU THAM KHẢO


[1] J. Postel and J. Reynolds, File Transfer Protocol, RFC 959, Internet Engineering Task Force, 1985.

[2] M. Horowitz and S. Lunt, FTP Security Extensions, RFC 2228, Internet Engineering Task Force, 1997.

[3] M. Allman and S. Ostermann, FTP Security Considerations, RFC 2577, Internet Engineering Task Force, 1999.

[4] P. Ford-Hutchinson, Securing FTP with TLS, RFC 4217, Internet Engineering Task Force, 2005.

[5] T. Ylonen and C. Lonvick, The Secure Shell SSH Transport Layer Protocol, RFC 4253, Internet Engineering Task Force, 2006.

[6] Rapid7, CVE-2024-4040: CrushFTP Unauthenticated Remote Code Execution Analysis, Rapid7 Blog, 2024.

[7] CrushFTP, Security Advisory and Compromise Incident Report July 2025, CrushFTP Wiki Documentation, 2025.

[8] watchTowr Labs, Analysis and Exploitation of Authentication Bypass Vulnerability CVE-2025-54309, Technical Report, 2025.

[9] Wireshark Foundation, Wireshark Uv's Guide: Following Protocol Streams, 2024.

[10] Netgate, pfSense Plus and CE Software Documentation: Firewall Rule Methodology, Netgate Docs, 2024.

[11] Link sheet: Phân công công việc

[12] Link github: Kịch bản demo

[13] Link docs: Nhật ký làm việc